

System Overview ? MedScribe-R-Us Platform

> Internal architecture reference. Source of truth for threat modeling,
> secure design, and security testing across the AppSec program.

1. What MedScribe-R-Us is

MedScribe-R-Us is a multi-tenant SaaS platform on Google Cloud Platform (GCP) that turns patient?clinician conversations into AI-generated SOAP notes and writes them back to the customer's EMR (Epic, Cerner) over FHIR R4. MedScribe operates as a HIPAA **Business Associate** for each customer health system.

Value proposition: cut clinician charting time from ~2 hours/day to under 20 minutes. Every AI note requires explicit clinician approval before it reaches the EMR ? a hard product and compliance requirement.

2. Core services (all GCP Cloud Run)

Service	Runtime	Responsibility
API Gateway	Cloud Run	Auth enforcement, rate limiting, routing, Cloud Armor WAF
Audio Ingestion Service	Cloud Run (Python FastAPI)	Receive audio, validate, write to GCS
Transcription Service	Cloud Run (Python FastAPI)	Call Speech-to-Text, store raw transcript
PHI Scrubbing Layer	Cloud Run (Python)	De-identify transcript before LLM submission
AI Summarization Engine	Cloud Run (Python FastAPI)	Build prompts, call Vertex AI (Gemini), parse output
Output Validation Service	Cloud Run (Python)	Detect hallucinated facts, policy violations
EMR Integration Service	Cloud Run (Python FastAPI)	FHIR R4 write-back to Epic/Cerner (SMART on FHIR)
Clinician Portal	Cloud Run (Next.js 15)	Review / approve / edit AI notes
Admin Portal	Cloud Run (Next.js 15)	Clinic-admin + MedScribe platform-admin functions
Notification Service	Cloud Run (Python)	Async webhooks, email, in-app notifications

All inter-service traffic stays on a private VPC. The API Gateway ('api.medscribe.internal') is the only internet ingress.

3. The conversation pipeline

- Record** ? clinician streams audio over WebSocket (TLS 1.3) to Audio Ingestion; segments are AES-256 encrypted to GCS ('medscribe-phi-audio-{tenant}') with per-tenant CMEK in Cloud KMS.
- Transcribe** ? Transcription Service calls Google Speech-to-Text (HIPAA BAA) and stores the verbatim transcript in MongoDB Atlas (encrypted at rest).
- Scrub** ? PHI Scrubbing Layer de-identifies the transcript (NER + regex, HIPAA Safe Harbor). The token map (token ? real value) is stored separately and never leaves the platform.
- Summarize** ? AI Summarization Engine sends the **de-identified** transcript to Vertex AI (Gemini) through 'vertex-proxy.medscribe.internal' over a VPC Service Controls perimeter. Output is treated as untrusted.
- Validate** ? Output Validation checks SOAP schema, hallucinations (SNOMED CT / RxNorm), PHI re-injection correctness, policy flags.

6. ****Approve**** ? the draft surfaces in the Clinician Portal. No note reaches the EMR without explicit clinician approval.
7. ****Write back**** ? EMR Integration builds a FHIR R4 DocumentReference and writes it to the customer's Epic/Cerner endpoint via SMART on FHIR OAuth 2.0.

4. External integrations & trust boundaries

Integration	Protocol	Auth	Data shared
Epic / Cerner EMR	FHIR R4 / HTTPS	SMART on FHIR OAuth 2.0	Approved notes (PHI)
Google Speech-to-Text	gRPC (GCP)	Service account	Raw audio (PHI)
Vertex AI (Gemini)	REST (GCP)	Service account	De-identified transcript only
MongoDB Atlas	TLS, private endpoint	mTLS + IP allowlist	All platform data (PHI)
Datadog	HTTPS agent	API key (Secret Manager)	Logs / metrics (no PHI)
Auth0	OIDC / OAuth 2.0	Tenant client creds	Patient / admin identity

5. Deployment

- One GCP project per environment: 'medscribe-prod', 'medscribe-staging', 'medscribe-dev'.
- Regions: 'us-central1' (primary), 'us-east1' (DR).
- Secrets in GCP Secret Manager; Workload Identity for service-to-service auth.
- Artifact Registry with vulnerability scanning; CI/CD GitHub Actions ? Cloud Build ? Cloud Run.

6. Security posture at program inception (pre-AppSec hire)

Property	State	Risk
Threat modeling	None	High
SAST / DAST / SCA	Not in CI/CD	High
Secrets detection	Not enforced	High
Container scanning	Not integrated	High
PHI scrubbing validation	Ad hoc	Critical
LLM prompt-injection testing	None	Critical
Incident response playbook	None	High
Vulnerability SLAs	Undefined	High

These gaps are the backlog for the first security hire.